



Actividad 02: Análisis y Planificación del Pentest

Reporte de Evidencias — Escaneo con Nmap sobre scanme.nmap.org

HACKER WOMEN COUNCIL • ETHICAL HACKING

- **Estudiante:** Yesica Pérez
- **Cohorte:** 1ª Generación
- **Fecha:** 20 de septiembre de 2026

1. Objetivo del ejercicio

Explorar el host autorizado scanme.nmap.org mediante distintas técnicas de escaneo con Nmap, con el fin de identificar puertos abiertos, servicios en ejecución, versiones de software y sistema operativo, comparando el alcance y la información obtenida por cada técnica.

Objetivo autorizado: scanme.nmap.org (host público provisto por el proyecto Nmap específicamente para pruebas y aprendizaje). Entorno de trabajo: Kali Linux.

2. Comandos ejecutados, resultados y conclusiones

Nº	Comando	Resultado obtenido	Conclusión
1	<code>nmap scanme.nmap.org</code>	Host activo (0.21s latencia). Abiertos: 22/tcp ssh, 80/tcp http, 9929/tcp nping-echo, 31337/tcp Elite. 25/tcp filtered (smtp). 995 cerrados.	Escaneo por defecto (top 1000) revela la superficie base: SSH y HTTP abiertos, más dos puertos atípicos (9929, 31337) propios del entorno de pruebas de Nmap. El 25 filtrado sugiere un firewall bloqueando SMTP.
2	<code>nmap -sn scanme.nmap.org</code>	Host up, 0.23s latencia. Sin info de puertos. Ejecución: 0.27s (muy rápido).	Confirma que el host está activo sin revelar puertos ni servicios. Útil solo como descubrimiento previo, no reemplaza un escaneo de puertos.
3	<code>nmap -sS scanme.nmap.org</code>	Resultado idéntico al comando 1: 22 ssh, 25 filtered, 80 http, 9929, 31337 abiertos. Ejecución: 6.40s.	Al correr Nmap como root (Kali), el escaneo por defecto ya usa SYN scan internamente; por eso -sS explícito da el mismo resultado que el comando 1, solo lo hace

Nº	Comando	Resultado obtenido	Conclusión
			explícito.
4	nmap -sT scanme.nmap.org	Mismos puertos que -sS: 22 ssh, 25 filtered, 80 http, 9929, 31337 abiertos. Ejecución: 12.25s (vs 6.40s del SYN scan).	El TCP connect scan detecta los mismos puertos que el SYN scan, pero casi el doble de lento (completa el handshake de 3 vías en cada puerto) y deja más rastro en los logs del servidor al completar conexiones reales.
5	nmap -sU --top-ports 20 scanme.nmap.org	Mayoría cerrados. open filtered: 67,68,138,500,631/udp. 123/udp (ntp) open. Ejecución: 15.17s (20 puertos).	UDP es notablemente más lento y ambiguo que TCP: sin respuesta, Nmap no puede confirmar apertura y reporta "open filtered". Escanear solo 20 puertos UDP tardó más que 1000 puertos TCP.
6	nmap -sV scanme.nmap.org	22/tcp OpenSSH 6.6.1p1 (Ubuntu) 80/tcp Apache httpd 2.4.7 (Ubuntu) 9929 Nping echo / 31337 tcpwrapped SO: Linux kernel.	Aporta información crítica: OpenSSH 6.6.1p1 y Apache 2.4.7 son versiones de ~2014, con CVEs conocidos publicados. En un objetivo real serían candidatas prioritarias a investigar.
7	nmap -sC scanme.nmap.org	ssh-hostkey: 4 claves (DSA, RSA, ECDSA, ED25519). http-title: "Go ahead and ScanMe!" http-favicon: Nmap Project.	Los scripts NSE por defecto exponen las claves públicas SSH del host y confirman su identidad vía el título/favicon HTTP, típicos del proyecto Nmap.
8	sudo nmap -O scanme.nmap.org	OS guesses: Linux 4.19-5.15 (95%), Linux 6.1 (95%), Linux 5.4 (92%), entre otras. Sin coincidencia exacta ("non-ideal conditions"). Distancia de red: 23 saltos.	La detección de SO por huella TCP/IP da varias probabilidades de kernel Linux pero sin certeza absoluta, algo normal en condiciones de red no ideales (host remoto, con NAT/firewalls de por medio).
9	nmap -p- scanme.nmap.org	Completado: 65535 puertos. Abiertos: 22,80,9929,31337. Filtered: 25 y 8 puertos más (874,1695,7600,9433,25890,39795,43151,53411). Ejecución: 692.12s (~11.5 min).	Al escanear todo el rango aparecieron 8 puertos filtrados adicionales invisibles en el top-1000 por defecto. Confirma que un escaneo por defecto puede dejar puntos ciegos, a costa de ~86 veces más tiempo (692s vs 7.92s).
10	nmap -T4 -A -v scanme.nmap.org	Combina versión+OS+scripts+traceroute en 30.66s. Detecta http-methods, uptime ~14.6 días, TCP Sequence Difficulty=260, 23 saltos vía Cogent/Akamai.	El modo agresivo (-A) resume en un solo comando lo obtenido por -sV, -sC, -O y --traceroute por separado, siendo mucho más eficiente para un reconocimiento completo, aunque también más "ruidoso" y detectable en la red objetivo.
11	nmap --script=banner scanme.nmap.org	22/tcp banner: "SSH-2.0-OpenSSH_6.6.1p1 Ubuntu-2ubuntu2.13". 9929/tcp: banner binario propio del protocolo nping-echo.	Confirma a nivel de banner crudo la misma versión de SSH que había detectado -sV, y muestra que nping-echo responde con un payload binario (eco), no con texto legible.

12	nmap --traceroute scanme.nmap.org	23 saltos hasta el host, RTT de 8.7ms a ~205ms. Ruta cruza red de Cogent (Brasil→NY→Chicago→	Revela la ruta de red real hasta scanme.nmap.org: el tráfico atraviesa la troncal de Cogent Communications a través de
N°	Comando	Resultado obtenido	Conclusión
		Denver→SF→San José) y termina en red de Akamai.	EE.UU. antes de llegar a la infraestructura de Akamai que sirve al host, explicando la latencia progresiva por salto.

3. Comparación general de técnicas

TCP connect vs SYN scan: ambas técnicas detectaron exactamente los mismos puertos (22, 25-filtered, 80, 9929, 31337), pero el TCP connect scan (-sT) tardó 12.25 segundos frente a los 6.40 segundos del SYN scan (-sS) — casi el doble. Esto se debe a que -sT completa el protocolo de enlace de 3 vías en cada puerto, mientras que -sS solo envía el SYN inicial ("half-open"), siendo más rápido y menos detectable en los logs del servidor objetivo.

Escaneo por defecto (1000 puertos) vs -p- (65535 puertos): el escaneo completo tardó 692.12 segundos (~11.5 minutos) frente a los 7.92 segundos del escaneo por defecto — casi 90 veces más lento — pero reveló 8 puertos filtrados adicionales (874, 1695, 7600, 9433, 25890, 39795, 43151, 53411) invisibles en el escaneo estándar. Esto evidencia el trade-off real entre cobertura total y tiempo de ejecución: un escaneo rápido puede dejar puntos ciegos.

Aporte de -sV, -sC y -O frente a un escaneo simple: mientras el escaneo básico solo indica qué puertos están abiertos, -sV identificó las versiones exactas de software (OpenSSH 6.6.1p1, Apache 2.4.7), -sC sumó las claves SSH del host y el título de la página web, y -O aportó una estimación probabilística del kernel Linux subyacente (sin coincidencia exacta, algo esperable al escanear a través de internet y no en red local).

Escaneo agresivo (-A) vs técnicas por separado: el comando `10 (-T4 -A -v)` reunió en 30.66 segundos la misma información que -sV, -sC, -O y --traceroute por separado, resultando mucho más eficiente para un reconocimiento completo — aunque también más "ruidoso" al generar más tráfico y solicitudes en un tiempo más corto, lo que lo hace más detectable por sistemas de defensa.

Traceroute: tanto el comando 10 como el 12 reconstruyeron la ruta de red completa (23 saltos) hasta el objetivo, pasando por la troncal de Cogent Communications y la red de Akamai, con RTTs consistentes entre ambas corridas (diferencias menores a 10ms), lo que confirma la estabilidad de la ruta de red hacia scanme.nmap.org.

4. Tabla de herramientas

Herramienta	Procedimiento a Realizar	Propósito y Qué se Espera Obtener
Nmap (Escáner de Red)	Lanzar escaneo perimetral controlado sobre el host objetivo mediante distintas técnicas: descubrimiento, SYN/connect, UDP, detección de versión, scripts NSE, detección de SO, escaneo completo de puertos, banners y traceroute.	Mapear los puertos abiertos y obtener el fingerprint de los servicios en escucha, sus versiones, el sistema operativo estimado y la ruta de red hacia el objetivo.

5. Conclusiones generales

El host scanme.nmap.org expone 4 puertos TCP abiertos (22-SSH, 80-HTTP, 9929 y 31337, estos últimos propios del entorno de pruebas de Nmap), 1 puerto filtrado conocido (25-SMTP) y 8 puertos filtrados adicionales fuera del rango habitual, detectados solo con el escaneo completo de todos los puertos. Corre sobre un kernel Linux (sin versión exacta determinable de forma remota) con versiones de software deliberadamente antiguas (OpenSSH 6.6.1p1, Apache 2.4.7, con un uptime estimado de ~14.6 días) pensadas para fines didácticos, y se encuentra alcanzable a través de la infraestructura de red de Akamai tras un recorrido estable de 23 saltos vía Cogent Communications. El ejercicio permitió comparar el costo en tiempo, el nivel de detalle y el nivel de sigilo de distintas técnicas de escaneo (descubrimiento, SYN, connect, UDP, detección de versión, scripts, OS, banners, agresivo y traceroute), consolidando una visión completa de la superficie de exposición del objetivo.